

บทที่ 2

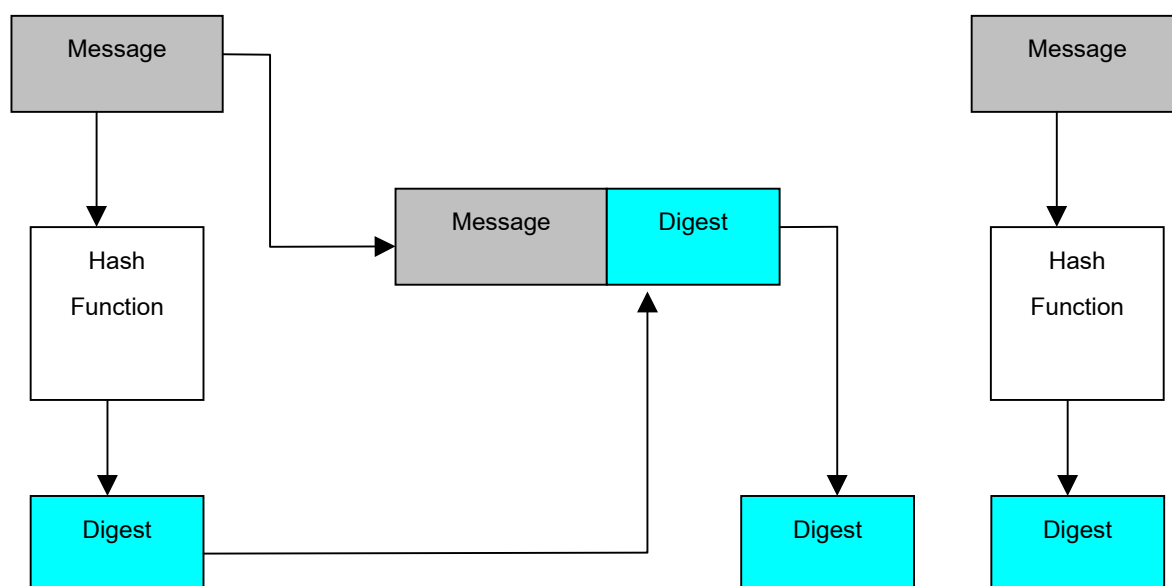
ลายมือชื่อดิจิตอล

2.1 การทำงานของลายมือชื่อดิจิตอล

ลายมือชื่อดิจิตอลใช้เมื่อต้องการความมั่นใจในแหล่งที่มา ของเอกสารเปรียบเหมือนลายมือชื่อ ซึ่งเฉพาะเจ้าของจริงที่สามารถคำนวณขึ้นมาได้ แต่ลายมือชื่อนี้สามารถพิสูจน์ได้กล่าวคือบุคคลอื่น สามารถตรวจสอบได้ว่าลายมือชื่อนั้นมาจากผู้สร้างจริง ๆ วิธีธรรมดาทั่วไปที่จะคำนวณลายมือชื่อดิจิตอล ก็คือการเข้ารหัสแบบคีย์ต่างหรือคีย์สาธารณะ เช่น ผู้ลงนามคำนวณค่าลายมือชื่อโดยใช้คีย์ส่วนตัว (Private key) และคนอื่นสามารถใช้คีย์สาธารณะ (Public Key) พิสูจน์ได้ว่าลายมือชื่อมาจากคีย์ส่วนตัวที่ตรงกัน คุณสมบัติที่สำคัญของลายมือชื่อดิจิตอลที่สำคัญนั้นจะต้องประกอบด้วย 2 ประการคือ

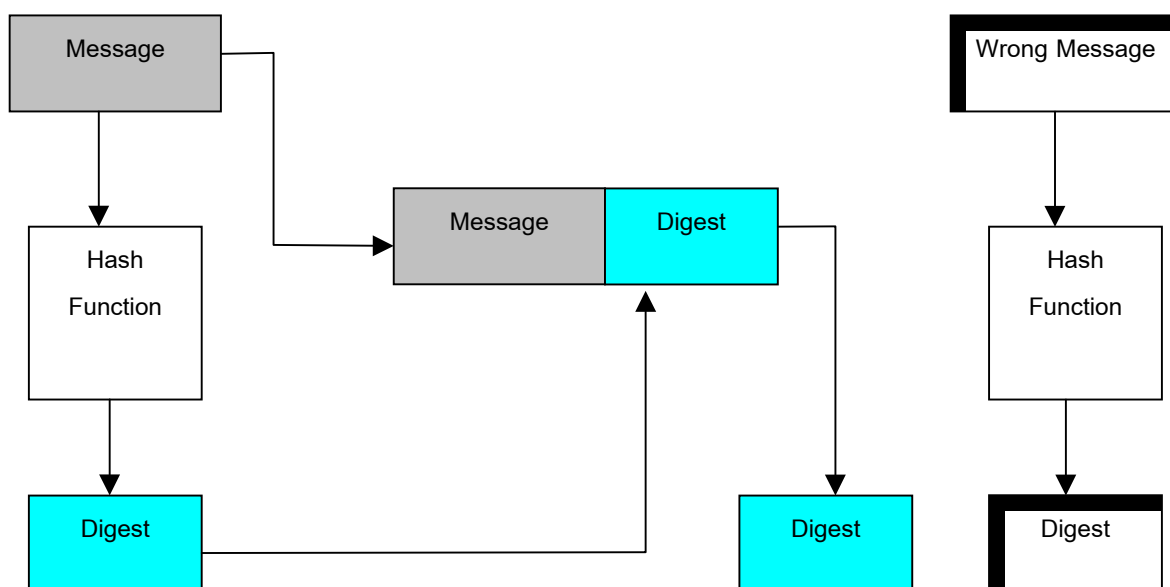
1. สามารถยืนยันได้ว่าข้อมูลที่ได้รับมานั้นไม่มีการเปลี่ยนแปลงระหว่างการส่ง
2. สามารถยืนยันได้ว่าข้อมูลนั้นได้รับการยืนยันจากผู้ลงลายมือชื่อจริง ๆ

วิธีการยืนยันว่าข้อมูลที่ได้รับมานั้นมีความถูกต้อง และไม่ได้รับการเปลี่ยนแปลงข้อมูลระหว่างการส่งนั้นสามารถทำได้โดยวิธีง่าย ๆ คือ การหาค่าแฮช (Hash Value) ดังรูปที่ 2.1



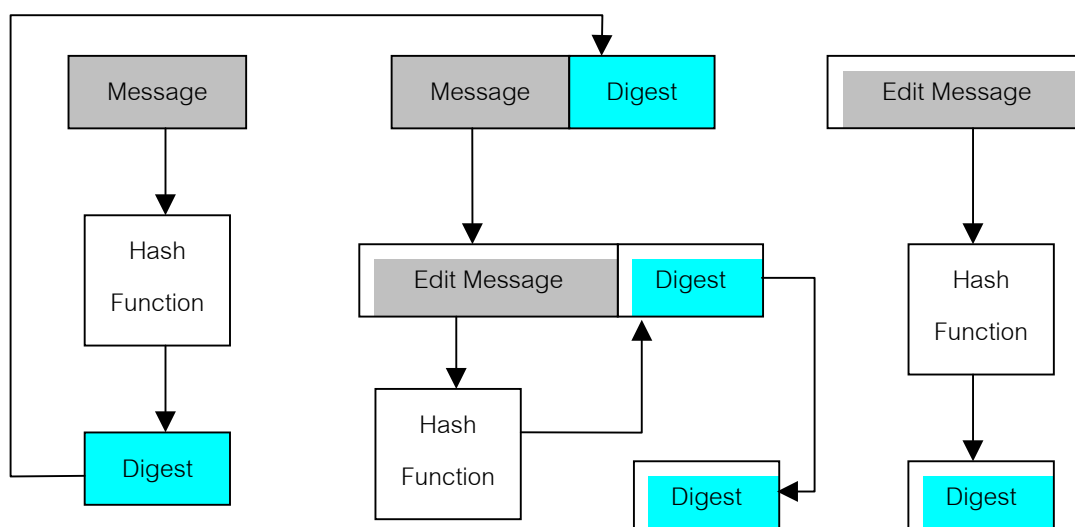
รูปที่ 2.1 วิธีการตรวจสอบความถูกต้องของข้อมูลแบบพื้นฐาน

จากรูปที่ 2.1 จะเป็นวิธีการที่ใช้ในการยืนยันความถูกต้องของข้อมูลอย่างง่าย โดยการหาค่าแฮช หรือจะเรียกว่าเมสเชงไดเจสต์ (Message Digest หรือ Digest) ก็ได้ซึ่งเมสเชงไดเจสต์ จะเปรียบเสมือนตัวแทนของข้อมูล ถ้าข้อมูลที่ได้รับเข้าสู่แฮชฟังก์ชันนั้นต่างกันค่าของเมสเชงไดเจสต์ที่ได้รับออกมานั้นก็จะต่างกัน แต่หากว่าข้อมูลที่ได้รับเข้าสู่แฮชฟังก์ชันนั้นเหมือนกันก็จะทำให้ค่าของเมสเชงไดเจสต์ที่ได้ออกมาเหมือนกัน มีโอกาสน้อยมากที่จะทำให้ข้อมูลเปลี่ยนไปแล้วยังได้เมสเชงไดเจสต์เหมือนเดิม



รูปที่ 2.2 เมื่อข้อมูลเกิดการผิดพลาด

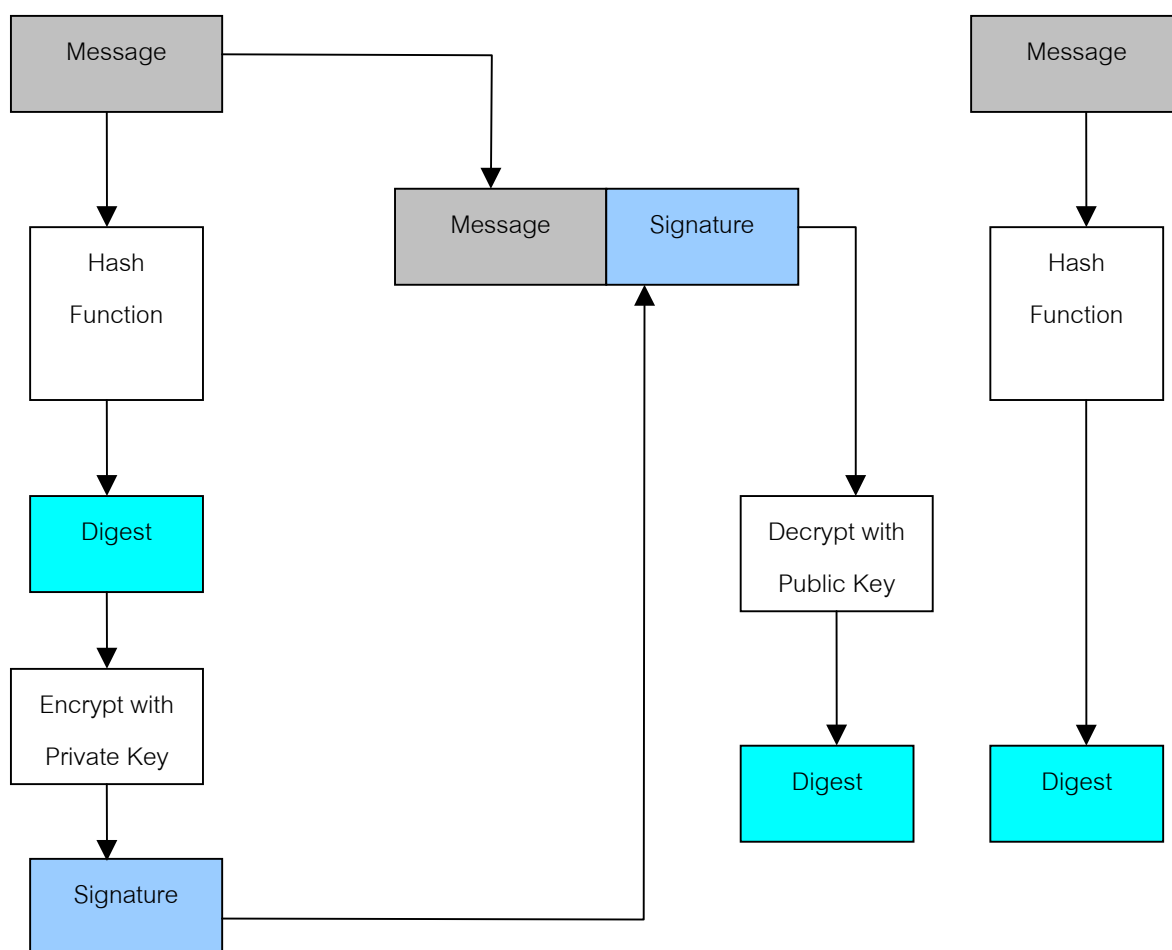
จากรูปที่ 2.2 แสดงให้เห็นทางด้านการยืนยันข้อมูลของผู้ส่งซึ่งจะมีทั้งข้อมูลและเมสเชงไดเจสต์ส่งมาให้ ทางด้านผู้รับก็ได้รับข้อมูลที่มีความผิดพลาดเกิดขึ้น (Wrong) เมื่อผู้รับทำการแฮชซึ่งได้เมสเชงไดเจสต์ออกมา เมื่อนำไปเปรียบเทียบกับเมสเชงไดเจสต์ที่ได้รับ จะเห็นว่าไม่เหมือนกัน ทำให้ผู้รับทราบได้ทันทีว่าข้อมูลที่ได้รับมานั้นมีความผิดพลาด แต่การทำวิธีนี้อาจไม่ปลอดภัยนักเนื่องจากหากผู้ต้องการปลอมแปลงทราบว่าคุณส่งใช้แฮชฟังก์ชันอะไร จะทำให้สามารถทำการเปลี่ยนแปลงข้อมูลนั้นได้ดูได้จากรูปที่ 2.3



รูปที่ 2.3 เมื่อมีผู้อ้างตัวเป็นผู้ส่ง

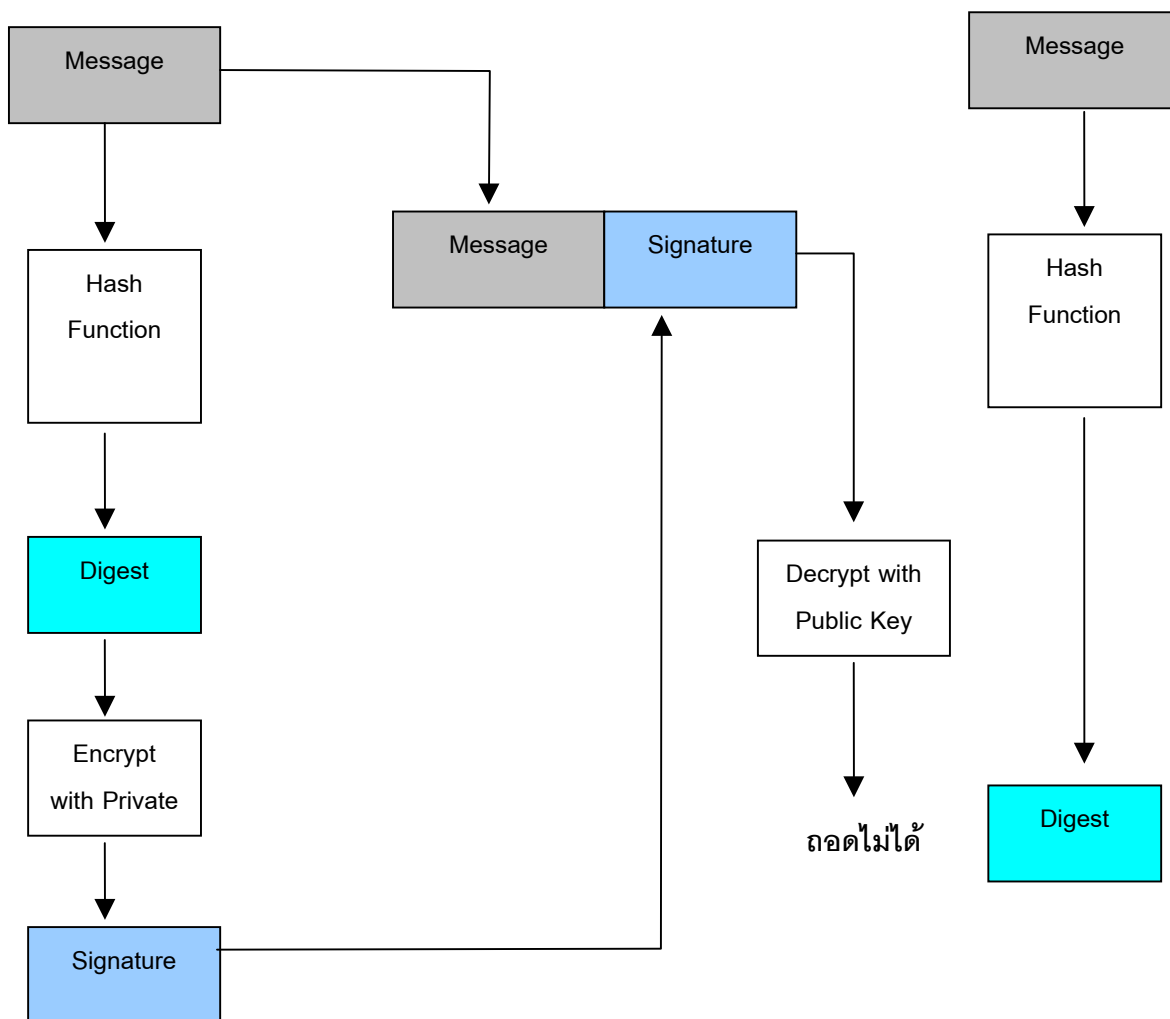
จากรูปที่ 2.3 เมื่อมีผู้อ้างตัวเป็นผู้ส่งนำข้อมูลที่ผู้ส่งส่งมาดัดแปลงแก้ไข แล้วใช้แฮชฟังก์ชันซึ่งเป็นอันเดียวกับผู้ส่งและผู้รับใช้จะทำให้ด้านผู้รับไม่อาจรู้ได้ว่าข้อมูลนั้นมีการเปลี่ยนแปลง ทำให้ไม่ปลอดภัย ดังนั้นจึงได้มีการใช้การเข้ารหัสเข้ามาช่วย

ในการยืนยันบุคคลผู้ส่งนั้นเป็นสิ่งที่ต้องทำตามหลังจากการยืนยันความถูกต้องของข้อมูล เทคนิคที่นิยมใช้ในการทำก็คือ ใช้เทคนิคคีย์ต่าง เช่น อาร์เอสเอ (RSA) โดยข้อความแรกเริ่มจะผ่านแฮชฟังก์ชันแล้วได้เป็นเมสเซจไคเจสต์ เพื่อเป็นการยืนยันความถูกต้องของข้อมูลก่อน จากนั้นจะนำเมสเซจไคเจสต์ ที่ได้ส่งไปเข้ารหัสกับคีย์ส่วนตัวของผู้ส่งเพื่อเป็นการยืนยันว่าเป็นเจ้าของเอกสารนั้นจริง และจะได้สิ่งที่เรียกว่าลายมือชื่อดิจิตอลออกมาส่งไปพร้อมกับข้อมูลด้วย ทางด้านรับนั้นจะเป็นวิธีการที่คล้ายกับด้านส่งโดยจะต้องเริ่มจากการหาเมสเซจไคเจสต์ของข้อมูลที่ได้รับมาเก็บไว้ก่อน จากนั้นจะนำลายมือชื่อดิจิตอลที่ได้รับมาด้วย มาทำการถอดรหัสด้วยคีย์สาธารณะของผู้ส่ง ในขั้นตอนนี้อาจจะสามารถยืนยันบุคคลผู้ส่งได้ เพราะถ้าหากผู้ที่ลงลายมือชื่อไม่ได้เป็นบุคคลที่เราคาดว่าเป็นเจ้าของ ก็จะไม่สามารถถอดลายมือชื่อดิจิตอลได้ ถ้าหากการยืนยันบุคคลผู้ส่งสำเร็จแล้วจะได้รับเมสเซจไคเจสต์ของข้อมูลก่อนจะส่งออกมา ด้านรับจะต้องทำการตรวจสอบความถูกต้องของข้อมูลด้วยโดยการนำเมสเซจไคเจสต์ที่คำนวณได้ในตอนรับข้อมูล กับเมสเซจไคเจสต์ที่ได้หลังจากการถอดรหัสลายมือชื่อดิจิตอลออกมา นำมาเปรียบเทียบกันถ้าหากเมสเซจไคเจสต์ที่ได้ออกมามีค่าเท่ากันนั้นแสดงว่าข้อมูลที่ได้รับนั้นเป็นข้อมูลเดียวกันจากทางด้านส่ง และไม่มีการเปลี่ยนแปลงข้อมูลระหว่างการส่ง ขั้นตอนการส่งและการรับของวิธีการนี้ แสดงไว้ในรูปที่ 2.4



รูปที่ 2.4 วิธีการสร้างลายมือชื่อดิจิตอลโดยใช้แฮชฟังก์ชันและคีย์ต่าง

จากรูปที่ 2.4 จะเห็นว่ามีความปลอดภัยมากยิ่งขึ้นในกรณีที่มีการปลอมแปลงจะเป็นดังรูปที่ 2.5



รูปที่ 2.5 ในกรณีมีผู้แอบอ้าง

จากรูปที่ 2.5 เมื่อมีผู้แอบอ้าง ผู้แอบอ้างไม่รู้คีย์ส่วนตัวของผู้ส่งจริง ๆ จึงใช้คีย์ของตัวเอง ซึ่งไม่ได้เข้าคู่กับคีย์สาธารณะทางฝั่งผู้รับ ทำให้ทางฝั่งผู้รับไม่สามารถถอดรหัสสลายมือชื่อดิจิทัลได้ จึงรู้ว่าไม่ใช่ผู้ส่งตัวจริงเป็นคนส่ง